CPEの表記揺れ・情報欠落に対応した製品情報に基づくNVDからの既知脆弱性特定手法

櫛引 淳之介 ⋆1,a)　林 嘉乃 ⋆1,b)　九鬼 琉[1]　佐々木 貴之[1]　吉岡 克成[1]

概要：インターネット上で観測された機器・ソフトウェア製品が既知脆弱性の影響を受ける可能性を判定するには，ベンダ名，製品名およびバージョンを，National Vulnerability Database（NVD）に登録されたCVE および CPE 情報と対応付ける必要がある．しかし，製品名と CPE 表記の差異や略称・表記揺れ，CPE 情報の欠落，製品固有のバージョン表記などにより，単純な文字列照合やバージョン比較では脆弱性を取りこぼす可能性がある．本研究では，これらの課題に対応する既知脆弱性特定手法を提案する．まず，NVD のキーワード検索と CPE 検索を併用して候補 CVE を取得し，表記揺れや CPE 情報欠落による検索漏れを補う．次に，大規模言語モデル（LLM）により製品情報と CVE の説明文・CPE 情報の意味的関連性を判定して関連 CVE を特定し，該当 CVE の CPE のうち対象製品に合致するものを選択する．最後に，CPE のバージョン範囲をルールベースで判定し，範囲欠落や独自表記で判定できない場合のみ LLM が CPE 情報と説明文から該当性を判断する．実際のインターネット広域スキャンで発見した製品 61 機種を対象に人手作成の Ground Truth と突き合わせて評価した結果，商用 API モデルを用いた場合に最終的な脆弱性判定で Precision 0.982 ／ Recall 1.000 を達成し，CPE 検索のみでは見逃す既知脆弱性も検出できることを確認した．

キーワード：脆弱性検知，IoT，CPE マッチング，NVD CVE，大規模言語モデル

Identifying Known Vulnerabilities from the National Vulnerability Database Based on Product Information Despite CPE Notation Variations and Missing CPE Information

Junnosuke KUSHIBIKI[1,a)]　Kano HAYASHI[1,b)]　Ryu KUKI[1]　Takayuki SASAKI[1]
Katsunari YOSHIOKA[1]

Abstract: To determine whether devices and software products observed on the Internet may be affected by known vulnerabilities, device information, including the vendor, product name, and version, must be matched with Common Vulnerabilities and Exposures (CVE) entries and Common Platform Enumeration (CPE) information in the National Vulnerability Database (NVD). However, simple string matching and version comparison often fail because of differences between product names and CPE identifiers, notation variations, missing CPE information, and product-specific version formats. This paper proposes a method for identifying known vulnerabilities that addresses these challenges. First, candidate CVEs are collected by combining NVD keyword search and CPE-based search to compensate for missed results caused by notation variations and missing CPE information. Next, a large language model (LLM) identifies relevant CVEs by determining the semantic relevance between device information and CVE descriptions together with CPE information, and then selects the CPEs corresponding to the target product. Finally, CPE version ranges are evaluated using rule-based comparison, while the LLM determines vulnerability applicability only when version ranges are unavailable or expressed in product-specific formats. Evaluation using 61 product models discovered through Internet-wide scanning and manually constructed ground truth showed that, with a commercial API-based LLM, the proposed method achieved a precision of 0.982 and a recall of 1.000 in the final vulnerability identification task, successfully detecting known vulnerabilities missed by CPE-based search alone.

Keywords: IoT vulnerability detection, Common Platform Enumeration (CPE), Common Vulnerabilities and Exposures (CVE), Large Language Models

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

インターネット上には，脆弱性を抱えたまま公開されている機器・ソフトウェア製品が多数存在することが知られている．こうした機器・製品はサイバー攻撃の入口となり，特に重要インフラに設置された機器が攻撃を受けた場合には広範な社会的影響が生じうる．この問題に対し我々は，インターネット広域スキャンと大規模言語モデル（LLM）を活用して，露出した IoT 機器の発見，リスク評価，管理者への対策提示までを一貫して自動化する統合システム「am I exposed?」の研究開発を進めている [1]．本システムのデバイス探索コンポーネントは，機器の WebUI 等を LLM で解析し，ベンダ名，製品名（型番），バージョンからなる機器情報をインターネット規模で抽出する [2], [3]．本論文は，この製品情報を National Vulnerability Database（NVD）等の脆弱性データベースと照合し，当該製品が影響を受ける既知脆弱性を特定する処理の設計と評価を扱う．なお，この処理は IoT 機器などのハードウェア機器に限らず，広域スキャンにより識別されうる製品全般（OS，ミドルウェア等のソフトウェア製品を含む）に適用可能である．

既知脆弱性を特定する最も直接的な方法は，ベンダ名，製品名，バージョンから共通プラットフォーム一覧（CPE: Common Platform Enumeration）形式の文字列を組み立て，NVD API [4] 等に問い合わせることである．しかし，LLM が抽出した製品情報の表記は CPE の正規化済み表記と一致するとは限らず，また CPE が登録されていない CVE も存在するため，CPE 検索だけでは脆弱性を取りこぼす．CVE 説明文へのキーワード検索を併用すればこれを補完できる一方，得られた候補から該当脆弱性を特定する段階で次の 3 つの課題が生じる．検索語を偶然含むだけの無関係な CVE の混入への対応（**課題 1：製品該当性**），1 つの CVE に付与された複数製品の CPE からの選別（**課題 2：CPE の選別**），バージョンによる絞り込みの欠如と統一的なバージョン比較規則の不在（**課題 3：バージョン該当性**）である．

本論文では，候補 CVE の収集と，これら 3 つの課題に対応する 3 つの判定タスクからなる既知脆弱性特定手法を提案する．NVD のキーワード検索と CPE 検索を併用して候補 CVE を収集した上で，**タスク 1：製品該当性判定**で各 CVE が対象製品のベンダ名・製品名に該当するかを LLM が判定する．**タスク 2：対象 CPE 選択**で該当 CVE の CPE 一覧から対象製品に関連するものを LLM が選択し，**タスク 3：バージョン該当性判定**で選択した CPE のバージョン範囲および CVE の説明文に基づき対象製品のバージョンが影響範囲に含まれるかを判定する．数値比較可能なバージョン表記はルールベースで，独自形式や説明文のみに記載がある場合は LLM で処理する．

評価では，実際のインターネット広域スキャンで得られた 61 機種を対象に，商用 API モデル gpt-5.6-luna・gpt-5.6-terra とローカル LLM モデル gpt-oss-120b の計 3 モデルについて，研究者 2 名が作成した Ground Truth との突合により精度を検証した．その結果，パイプライン全体の最終出力（タスク 3）では，3 モデルすべてが Recall 0.98 以上を達成し，Precision は luna で 0.982，terra・oss-120b で 1.000 となった．対象 CPE 選択の段階では，luna・terra が Precision 1.000 を達成する一方 oss-120b はやや劣り，NVD の CPE 命名慣行に起因する境界事例などモデルの違いによらず残る誤りと，特定のモデルにのみ残る誤りとが確認された．また，候補の収集や絞り込みを経ずに CVE を直接列挙させるベースラインとの比較では，同一モデルを用いても提案手法が大きく上回り（例えば luna で Precision 0.661 ／ Recall 0.661 に対し提案手法は 0.982 ／ 1.000），本手法の多段構成そのものが検出精度に寄与していることを確認した．

本論文の貢献は以下の通りである．

(1) スキャン由来の製品情報から既知脆弱性を特定する際の課題を，CPE 検索による取りこぼしと，その対応としてキーワード検索を併用したときに生じる課題に整理した．
(2) CPE 辞書を経由しない検索と，LLM およびルールベース判定による絞り込みを組み合わせた既知脆弱性特定手法を設計・実装した．
(3) Ground Truth との突合により，実際のスキャンで発見した 製品 61 機種を対象に提案手法を評価し，商用 API モデルとローカル LLM の双方についてタスク別の精度と誤りの傾向を明らかにした．また, 同一世代内で最も低コストな商用 API モデルである gpt-5.6-luna で Precision 0.982 ／ Recall 1.000 を達成することを確認した．

2. 背景と関連研究

2.1 Common Platform Enumeration (CPE)

CPE は，IT 製品を一意に識別するための NIST の命名規則であり，NVD では各 CVE が影響を受ける製品の記述に用いる．CPE 2.3 の文字列表現は，接頭辞 `cpe:2.3` に続き 11 個の属性をコロン区切りで並べたものである [5]（図 1）．NVD の CPE では，属性値を小文字化し空白をアンダースコアに置換した表記をとり，値を限定しない属性はワイルドカード * で表す．図 1 は，TP-Link 製無線アクセスポイント EAP225 のファームウェア（バージョン 5.1.0）を指す例である．

[1] 横浜国立大学
Yokohama National University
[a)] kushibiki-junnosuke-hf@ynu.ac.jp
[b)] hayashi-kano-jd@ynu.jp
[⋆] 櫛引 淳之介と林 嘉乃は本研究に同等に貢献した．

© 2026 Information Processing Society of Japan

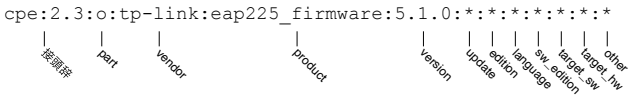


図 1 CPE 2.3 の文字列表現の構造（CVE-2023-48724 に付与された CPE）

2.2 脆弱性データベースにおける製品情報の品質

NVD をはじめとする脆弱性データベースには欠損や表記の不整合が存在することが知られており，ベンダ名・製品名の綴り誤りや略記による同一実体の複数表記 [6]，CVE・NVD・ベンダアドバイザリ間での影響製品やバージョン範囲の記載の食い違い [7] が報告されている．特に NVD 中の CVE エントリに含まれる CPE については，ベンダ名の 50.18% で他エントリとの表記揺れが見られることが指摘されている [8]．また Ashokkumar らは，単純な文字列マッチングでは NVD の CVE フィードに含まれるユニークな CPE の 45%以上が公式 CPE 辞書と一致せず，中でもバージョン文字列の不一致が最大の要因であることを報告している [9]．CPE 文字列の厳密一致に依存する脆弱性特定手法は，これらの不整合による取りこぼしを避けられない．

2.3 製品情報と脆弱性の対応付け

インターネット全域を対象とした機器発見サービスの Shodan [10] が機器に付与する既知脆弱性の CVE タグの多くは，バナー情報から推定した製品とバージョンを CVE に対応付けたものである．Huang らは，脆弱性の有無を直接確認するスキャンとの突合により，このタグの大部分（多くの CVE で 95% 超）が偽陽性であることを示し，その原因としてバナー情報から CPE への変換や CPE と CVE の対応付けの誤りを挙げている [11]．

こうした対応付けを支援する手法として，CVE の説明文から固有表現抽出により CPE に相当する製品情報を抽出する手法 [12]，NVD に登録された CPE 等の構成情報を統一スキーマへ標準化して照合する手法 [8]，文字列類似度等により製品情報と CPE を比較する手法 [13][14] などが提案されている．また Chen らは，脆弱性レポートから影響を受けるライブラリ名を LLM で生成する手法を提案している [15]．これらの手法は，学習モデルや正規化辞書の構築と維持，あるいは照合先の CPE や整備されたパッケージ識別子の存在を前提とする．本研究の手法は，CPE 辞書やモデルの追加学習を必要とせず，LLM の文脈判定により CPE 未登録の CVE も含めて特定する点で既存研究と異なる．

3. 研究課題

本章では，スキャン由来の製品情報（ベンダ名，製品名，バージョンの 3 つ組）を入力とする既知脆弱性特定の課題を整理する．最も直接的な方法は，これらの情報から CPE 形式の文字列を組み立て NVD API に問い合わせること（以下，CPE 検索）である．

3.1 CPE 検索を用いる場合の課題

CPE 検索には次の課題があり，脆弱性を取りこぼす．

一つは表記揺れによる検索漏れである．製品情報の表記はスキャン対象の WebUI に依存し CPE の表記と一致する保証がない一方，CPE 検索は完全一致に近い照合を行うため，表記が僅かに異なるだけで検索漏れが生じる．例えば TP-Link 製ルータの型番 ER605 と推定された場合，NVD 上の CPE は製品ライン名と合わせて omada_er605 として登録されており（例: CVE-2024-25139），WebUI 上の型番表記をそのまま用いても一致しない．さらに 2.2 節の通り NVD の CPE 自体にも表記揺れが存在するため [8]，入力側の正規化だけでは解消できない．

もう一つは CPE 情報の欠落である．CPE は CVE の公表後に NVD の分析を経て付与されるため [16]，付与されていない CVE も存在し，これらは入力 CPE をどう工夫しても検索結果に現れない．実際，MikroTik RouterOS の収集では，CVE-2025-10948 をはじめ複数の CVE で vulnStatus が Awaiting Analysis や Deferred（解析未了）のまま CPE 未付与の事例が確認された．

3.2 キーワード検索を用いる場合の課題

前節の 2 課題はいずれも CPE を検索キーとすることに起因するため，CPE を介さない到達経路として CVE 説明文へのキーワード検索の併用が必要である．自然言語で書かれた説明文を照合先とすることで，正規化済み表記との不一致も CPE の欠落も回避できる．しかし，収集した候補から該当脆弱性を特定する段階で新たに 3 つの課題が生じる．

課題 1：候補 CVE の製品該当性．キーワード検索は検索語が説明文に現れるかのみで候補を返すため，検索語を偶然含むだけの無関係な CVE も混入する．この混入を表記の照合で排除すれば表記揺れによる取りこぼしが絞り込みの段階で再発するため，候補 CVE が対象製品に該当するかを，表記によらず説明文や CPE の記述の意味に基づいて判定する必要がある．

課題 2：対象製品に対応する CPE の選別．1 つの CVE には複数製品の CPE が付与されうるため，該当 CVE でも CPE 一覧に無関係なものが含まれ，残ったままではバージョン判定を誤る．そのため，バージョン該当性の判定に先立って対象製品の CPE を先に選び出す必要がある．

課題 3：バージョン該当性．NVD の versionStartIncluding 等との照合にはバージョン文字列の順序付けが必要だが，その規則は標準化されていない [17]．semantic versioning に従う製品は一般的な規則で比較できるが，独自形

© 2026 Information Processing Society of Japan

式のバージョン表記（例: 1.43R02）では柔軟な比較が求められる．また，CPE 情報が欠落した CVE では照合すべきバージョン範囲が得られず，説明文中の記述（例: “before 1.2.0”）からバージョン条件を読み取ることになる．

4. 提案手法

4.1 手法の概要

3 章の課題を踏まえ，製品情報（ベンダ名，製品名，バージョン）を入力とし，当該機器・ソフトウェア製品が影響を受ける既知脆弱性の一覧を出力する手法を提案する．全体像を図 2 に示す．本手法は，候補 CVE の収集（4.2 節）と，これに続く 3 つの判定タスクからなる．収集は，CPE 検索の取りこぼし（3.1 節）に対応してキーワード検索を併用し，タスク 1〜3（4.3〜4.5 節）は，その併用が生む課題 1〜3（3.2 節）に対応する．

判定を担う手段は，タスクの性質で使い分ける．表記の異なる製品名の照合や，説明文からの影響範囲の読み取りは，規則化できないため LLM に委ねる．一方，バージョン範囲との照合のうち数値として比較できる部分は，LLM を介さずルールベースで処理する．

4.2 候補 CVE の収集

候補 CVE は NVD API に対する 2 系統の検索で収集する．第一のキーワード検索は，製品名を検索語として，CVE の説明文へ全文検索（keywordSearch パラメータの指定）を行う．第二の CPE 検索は，製品名から CPE を組み立て，CVE に付与された CPE の指定属性のみによる照合（virtualMatchString パラメータの指定）を行う．この際，小文字化し空白をアンダースコアに置換して CPE 形式の文字列とする．両系統が発行するリクエストの詳細は，付録 A.2 に示す．

候補を網羅的に集めるため，両系統とも検索条件には製品名のみとし，ベンダ名・バージョンは含めない．条件を緩めることで混入する候補は，タスク 1〜タスク 3（4.3〜4.5 節）で除去されるが，収集段階での取りこぼしは後段で回収できないためである．実際，ベンダ名を検索語に加えると説明文にベンダ名が現れない CVE を取りこぼし，バージョンを条件に含めれば，バージョン範囲の記述形式に依存した検索漏れが生じる．例えば “BUFFALO VR-S1000” では該当 CVE が 0 件であるのに対し，製品名のみの “VR-S1000” では 4 件が該当する．

両系統とも CPE 辞書を経由せず NVD を直接検索するため，CPE 辞書と NVD に掲載された CPE の不一致 [9] の影響を受けない．CPE 未付与の CVE はキーワード検索のみ，説明文に製品名が現れない CVE は CPE 検索のみが到達できるため，併用により網羅的に収集できる．

4.3 タスク 1：製品該当性判定

課題 1 に対応し，キーワード検索由来の候補 CVE が対象製品に該当するかを CVE 単位で判定し，非該当のものを除去する．なお，CPE 検索は CPE の product 属性が対象製品と完全一致する CVE のみを返し，無関係な製品の CVE が混入する余地がないため，CPE 検索由来の候補は本タスクを経ずにタスク 2 へ渡す．

判定に用いるプロンプトの全文は，付録 A.3 の図 A·2 に示す．LLM には，製品情報（ベンダ名・製品名）と，候補 CVE を 20 件ずつ，各 CVE の説明文および CPE 適用条件から抽出した影響製品の一覧とともに 与え，CVE ごとの該当性の判定と判定理由を返させる．製品情報が上流の自動処理による抽出結果で表記が保証されないことを前提に，CPE 表記との照合は文字列一致ではなく意味に基づいて行わせる．また，影響製品の一覧に対象製品が現れれば説明文に型番が無くても該当とし，一覧が空の CVE は説明文のみから判定させて，説明文が対象製品を挙げている場合に限り該当とする（ベンダ名のみの一致では不十分とする）．非該当と判定させるのは，これらのいずれにも当たらず該当性を確認できない場合に限る．

4.4 タスク 2：対象 CPE 選択

課題 2 に対応し，候補 CVE に付与された CPE の一覧から対象製品に関連するものを LLM で選択する．対象は，タスク 1 で該当と判定された CVE と，CPE 検索由来の CVE である．

判定に用いるプロンプトの全文は，付録 A.3 の図 A·3 に示す．LLM には，製品情報（ベンダ名と製品名）と，当該 CVE に付与された CPE の一覧を与え，選択した CPE 文字列の一覧を返させる．選択は製品の粒度で行い，バージョン・ビルド識別子・パートタイプの違いは該当しうる CPE を残す一方，対象製品そのものでない CPE（兄弟製品や依存コンポーネントを含む）は明示的に除外するよう指示する．後段のタスク 3 ではバージョンのみが絞り込まれ製品の同一性は絞り込まれないため，該当しうる CPE を広く残す設計では，兄弟製品や依存コンポーネントの CPE が最終出力まで残り過検出に直結することを予備実験で確認しており，これを踏まえた設計である．また，入力の CPE 文字列をそのまま返すことを指示した上で，出力を入力の CPE 一覧と突合し，一致するもののみを採用することで，CPE 文字列の改変や捏造を排除する．

4.5 タスク 3：バージョン該当性判定

課題 3 に対応し，対象製品のバージョンが脆弱性の影響範囲に含まれるかを判定する．判定はルールベースと LLM の 2 段階で行う．まず，タスク 2 で選択した CPE のバージョン範囲（versionStartIncluding 等）および固定バージョンと，対象製品のバージョンとを数値的に比較し，

© 2026 Information Processing Society of Japan

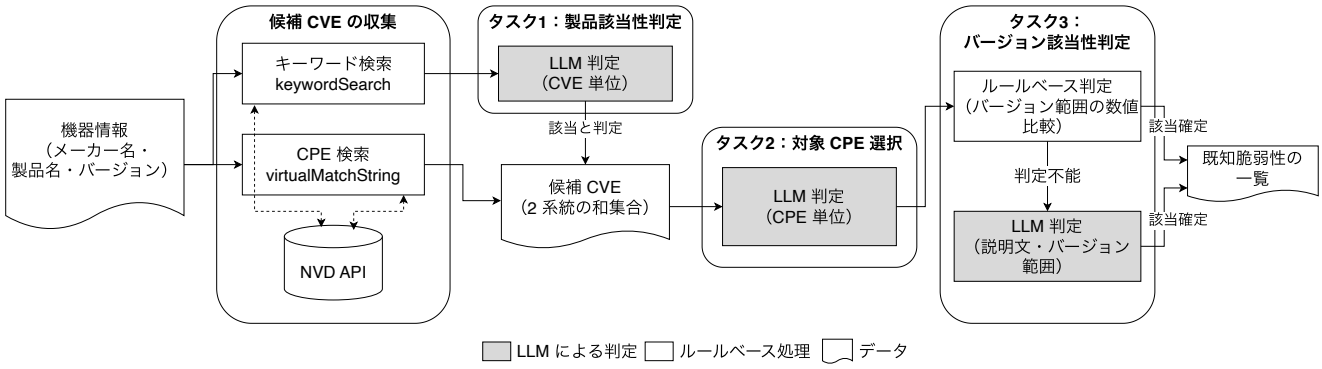


図 2　提案手法の全体図

該当確定，非該当確定，判定不能の 3 通りに分類する．3.2 節で述べた通りバージョン文字列の比較規則は標準化されておらず，独自形式の表記を一般的な規則で解釈すると誤った判定が生じうる．そこで数値比較は，数字とドットのみからなる表記に限定して適用し，それ以外の表記（例: 1.43R02）は判定不能に分類する．またバージョン制約を持たない CPE は，それ単独では該当か非該当かの判定材料としない．CVE に複数の CPE が付与されている場合は，いずれか 1 つの CPE で範囲内と確定できれば該当確定とする一方，非該当確定は，比較できた全ての CPE で範囲外であり，かつ数値比較できずに除外した CPE が残っていない場合に限る．この非対称な規則により，確信の持てない非該当を確定させず，判定の付かない候補は取りこぼしなく LLM 判定に回す．

判定不能に分類された CVE についてのみ，LLM がバージョン該当性を判定する．判定に用いるプロンプトの全文は，付録 A.3 の図 A·4 に示す．LLM には，製品情報（ベンダ名，製品名，バージョン）と，候補 CVE を 20 件ずつ，各 CVE の説明文および前段で絞り込んだ CPE のバージョン範囲情報とともに JSON 形式で与え，CVE ごとの該当性の判定，判定理由，判定に用いた CPE を返させる．プロンプトでは，まず対象製品と同一の製品ラインであることを確認させ，異なる場合はバージョンによらず非該当とする．影響範囲は CPE のバージョン範囲を優先し，これが無ければ説明文中の「before X」等の表現から読み取らせる．その際の境界の解釈（「before X」は X を含まない等）と，バージョンを文字列でなく構成要素ごとに数値として比較させる指示は，プロンプト中で明示的に与えている．利用可能なバージョン制約がなければ非該当とする．

5. 評価

5.1 評価方法

提案手法が 3 章の課題の下でも既知脆弱性を十分な精度で特定できることを示すため，実際のインターネット広域スキャンで発見した製品のデータを用いて精度評価を行った．

具体的には，実データを入力として提案手法による脆弱性特定を実行し，その出力を，同じタスクを研究者が実施した結果（Ground Truth）と比較した．精度がモデルの規模や運用形態にどの程度依存するかを確認するため，商用 API を用いる gpt-5.6-luna と gpt-5.6-terra，および外部へのデータ送信を伴わずローカル環境で動作する gpt-oss-120b の 3 種類の LLM で提案手法を実行し，結果を比較した．luna と terra はいずれも同一世代の商用 API モデルであり，前者は最も低コストな tier，後者はその上位 tier に位置づけられる．同一世代内で tier を変えることで，コストと精度のトレードオフを確認する狙いがある．

また，手法設計の効果を確認するため，候補の収集や絞り込みを経ずに製品情報から該当 CVE を LLM に直接列挙させる手法でも同様に脆弱性特定を行い，提案手法と比較した．

5.2 評価データセットの作成

本研究の評価対象データセットは，2025 年 7 月〜2026 年 3 月に実施した日本国内広域スキャンの結果から構築した．デバイス探索コンポーネント [2] が WebUI を LLM で解析し，ベンダ名・製品名・バージョンを自動抽出した．

WebUI の収集に成功した 94,681 件を同一製品と推定される IP でクラスタリングし，各クラスタの代表および構成要素の WebUI からベンダ名・製品名・バージョンの 3 項目すべてを特定できたものを対象とした結果，71 件が得られた．このうち，3 項目すべてが一致する重複を除き，計 61 機種を評価対象データセットとした．評価対象製品のカテゴリ内訳は付録 A.5 に示す．提案手法はハードウェア・OS・アプリケーションを問わず適用できる一方で，本評価で得られたデータセットはハードウェア機器（IoT 機器）に偏っており，この偏りは提案手法自体の適用範囲の限界ではなく，上流の機器情報抽出手法 [2] が WebUI 上の視覚的な表示から製品情報を抽出する方式であることに起因すると考えられる．

この 61 機種に候補 CVE の収集（4.2 節）を行った結果，キーワード検索で計 67 件，CPE 検索で計 105 件の（製

© 2026 Information Processing Society of Japan

品，CVE）の組が得られ，重複 36 件を除くと計 136 件となった．タスク 1 の評価では，キーワード検索のみで得られた 31 件（67 件から重複 36 件を除いたもの）の CVE を用いた．タスク 2・3 では，重複を除いた計 136 件の CVE を評価に使用した．

さらに，研究者 2 名が LLM の代わりに人手でタスクを実行し，Ground Truth を作成した．入力は各タスクで LLM に与える情報と同一の，CVE の記述（説明文および CPE 適用条件）と対象製品の情報（ベンダ名，製品名，バージョン）のみとし，判定材料をモデルと揃えた．判断基準の個人差を排除するため，人手判定は 2 名が独立に行った上で突き合わせ，不一致は協議して最終的な Ground Truth を確定した．タスク 2・3 の評価対象集合を前段の判定結果に依存させないため，Ground Truth は収集段階の全候補に対して作成した．

人手判定が必要な範囲はタスクごとに異なる．タスク 1 は 31 件全てを人手判定し，このうち該当と判定されたのは 11 件であった．タスク 2 は，CPE の product 属性が対象製品と完全一致するか機械的に一意判定できない 11 件のみ人手判定した．タスク 3 は，数値バージョン範囲による機械的判定ができない 17 件のみ人手判定した．

5.3 評価指標

各タスクの出力を，人間の判定（正解）とモデルの判定の一致・不一致により 4 通りに分類する：(1) 両者とも該当と判定した TP（True Positive），(2) 人間は非該当だがモデルは該当と判定した FP（False Positive，過検出），(3) 人間は該当だがモデルは非該当と判定した FN（False Negative，見逃し），(4) 両者とも非該当と判定した TN（True Negative）．これらから適合率 Precision $= TP/(TP + FP)$ と再現率 Recall $= TP/(TP + FN)$ を算出する．Precision はモデルが該当と判定した結果の信頼度を，Recall は本来該当する CVE の取りこぼしのなさを示す．なお，対象 CPE 選択（4.4 節）の評価は，1 つの CVE が複数の CPE を持ちうるため CPE 単位で TP/FP/FN を集計する．

5.4 提案手法の精度

タスク別の評価結果を表 1 に示す．パイプライン全体の最終出力（タスク 3）で，luna は Precision 0.982 ／ Recall 1.000，terra は Precision 1.000 ／ Recall 1.000，oss-120b は Precision 1.000 ／ Recall 0.982 を達成した．

タスク 1：製品該当性判定． luna・oss-120b の FP（CVE-2026-64246，CVE-2026-11555）は両モデルで完全に一致した．いずれも，判定対象の文字列（ドライバ名や型番）に製品名が偶然含まれていたことに起因する誤りであった．terra は，対象製品（DGS-1100-08P）と型番末尾のみ異なる別製品（DGS-1100-08PD）を同一製品と誤認した CVE-2026-11555 のみ FP であった．

タスク 2：対象 CPE 選択． luna・terra は Precision 1.000 を達成した一方，oss-120b はやや劣った（0.981）．3 モデル共通の FN は，D-Link DGS-1100 関連の 1 件であった．対象製品 DGS-1100-08P に対し，NVD 上でシリーズ全体を指す表記（接尾辞なしの dgs-1100）を持つ CPE を，3 モデルとも同一製品ラインとして選択しなかった．oss-120b はこれに加え，兄弟製品（WXR-1900DHP3 に対する WXR-1900DHP2）の CPE を 6 件で一律に誤選択したほか，“_firmware” 接尾辞付き CPE（TP-Link ER605）の除外誤り 7 件などがあった．

タスク 3：バージョン該当性判定． terra は Precision・Recall とも 1.000 と，FP・FN のいずれも生じなかった．luna の FP は GIGAPOD（対象バージョン “00.00.00”）× CVE-2014-5329 の事例で，“00.00.00” は WebUI 上の表示に由来し実際のバージョンでなくエラー表示である可能性が高い．luna はこれを数値比較し脆弱範囲（3.01.02 以下等）に該当すると判定したが，Ground Truth 上は非該当であった．oss-120b の FN 1 件は，タスク 2 で候補から除外してしまった CPE がタスク 3 では判定対象にすらならず見逃しとなった．

製品該当性判定で該当と判定された 11 件の CVE のうち，最終的にバージョンが該当範囲内で脆弱と判定されたのは 3 件（TP-Link ER605 の CVE-2024-25139，CVE-2024-1179，CVE-2024-1180）であった．これらは NVD 上の CPE が製品ライン名を接頭辞に持つ omada_er605 として登録されており，型番表記 ER605 のみでは CPE 検索に一致しない（3.1 節）．すなわち CPE 検索のみに依存する手法は，本データセットで少なくとも 3 件の既知脆弱性を見逃す．提案手法は，キーワード検索の併用とタスク 1〜3 の判定によりこの取りこぼしを回収できることを確認した．この 3 件は luna・terra の最終出力では検出されたが，oss-120b では CVE-2024-25139 のみ見逃された．

5.5 ベースラインとの比較

提案手法は 3 つの判定タスクなど多段階の構成をとるが，この設計自体が性能に寄与しているかを検証するため，候補の収集や絞り込みを経ず製品情報から該当 CVE を LLM に直接列挙させる単純なベースライン（以下，direct）と比較した．direct は，NVD を情報源として明示した上で web 検索機能を有効化した Chat Completions API を製品ごとに 1 回呼び出す構成である．システムプロンプトおよび出力スキーマは付録 A.4 に示す．direct のモデルには提案手法と同一のモデル（gpt-5.6-luna，gpt-5.6-terra）を用いたが，gpt-oss-120b は web 検索機能を前提とする direct の構成に適用できないため，比較対象から除外した．評価には，提案手法の評価（5.4 節）と同一の 61 機種および同一の Ground Truth を用いた．

表 2 に示す通り，direct は提案手法に対していずれのモ

© 2026 Information Processing Society of Japan

表 1 モデル別・タスク別の Precision / Recall

モデル	タスク	TP	FP	FN	Precision / Recall
gpt-5.6-luna（商用 API，軽量モデル）	タスク 1: 製品該当性判定	11	2	0	0.846 / 1.000
	タスク 2: 対象 CPE 選択	329	0	1	1.000 / 0.997
	タスク 3*: バージョン該当性判定	56	1	0	0.982 / 1.000
gpt-5.6-terra（商用 API，上位 tier）	タスク 1: 製品該当性判定	11	1	0	0.917 / 1.000
	タスク 2: 対象 CPE 選択	327	0	3	1.000 / 0.991
	タスク 3*: バージョン該当性判定	56	0	0	1.000 / 1.000
gpt-oss-120b（ローカル LLM）	タスク 1: 製品該当性判定	11	2	0	0.846 / 1.000
	タスク 2: 対象 CPE 選択	311	6	19	0.981 / 0.942
	タスク 3*: バージョン該当性判定	55	0	1	1.000 / 0.982

注：* タスク 3 の指標は，パイプライン全体の最終出力に対する評価であり，タスク 1・2 の誤りの伝播・吸収を含む．

表 2 提案手法と direct ベースラインの比較

手法	モデル	TP	FP	FN	Precision / Recall
提案手法	gpt-5.6-luna	56	1	0	**0.982 / 1.000**
	gpt-5.6-terra	56	0	0	**1.000 / 1.000**
direct	gpt-5.6-luna	37	19	19	0.661 / 0.661
	gpt-5.6-terra	42	31	14	0.575 / 0.750

デルでも Precision・Recall とも大きく劣る．FN は，同一製品に紐づく CVE 数が多い製品に集中しており，全件が提案手法の候補収集（4.2 節）で取得可能なものであった．

FP は 2 種類に分けられる．一方は，実在する CVE を誤って対象製品に結び付けた事例であり，特に terra では，対象製品が内部で利用する依存コンポーネント（Samba 等）の既知脆弱性を製品自体の脆弱性として紐付ける事例が多数確認された．これらは NVD 上の CPE で対象製品への言及がなく（例: CVE-2021-31439 は依存コンポーネントを組み込む Synology 製品には個別に CPE が付与される一方，対象製品には付与されていない），依存コンポーネントの脆弱性を製品へ過剰に一般化した事例と考えられる．もう一方（luna 9 件，terra 7 件）は，Ground Truth の評価対象集合（NVD に CPE も型番の記載もなく，提案手法の候補収集でも到達できない CVE）に含まれないため機械的に FP として集計されているに過ぎず，内容を精査すると実際に対象製品に該当する可能性が高い．すなわち，提案手法では見つけられない既知脆弱性を，direct が拾い上げていたケースも含まれている．

6. 考察

6.1 direct と提案手法の比較

提案手法は，5.5 節で見た direct の見逃し（FN）と誤った対応付け（FP）という 2 つの誤りを，異なる段階でそれぞれ軽減している．FN は，direct の 1 回の呼び出しでは候補を取得しきれないという情報取得段階の限界に起因する．提案手法は，キーワード検索と CPE 検索を併用した候補収集（4.2 節）により，こうした CVE も候補として取得できる．FP のうち，terra に見られた対象製品と依存コンポーネントの混同は，判断段階に対応する誤りである．提案手法のタスク 2（4.4 節）が，対象製品そのものでない CPE を選択の対象から明示的に除外する設計としているため，この種の誤りは防ぐことができる．

一方，direct が web 検索を通じて，提案手法の候補収集では到達できない既知脆弱性を拾い上げていた点は，提案手法の限界でもある．NVD の検索に依存する提案手法は，NVD に CPE も型番の記載もない CVE には原理的に到達できない．ただし，direct の情報取得は網羅的ではなく，同一製品に紐づく CVE 数が多い場合には見逃しも生じており（前述の FN），NVD の範囲外にある情報を安定して拾えているわけではない．

すなわち，同一の LLM を用いても direct はこれらの誤りを回避できず，提案手法の精度はモデルの性能のみによらず，この多段構成の設計に由来するといえる．

6.2 モデル選択と運用形態

5.4 節の結果は，特定のモデルにのみ残る誤りと，全モデルに共通する誤りが区別できることを示している．

同一世代内で tier のみを変えた luna と terra は，最も安価な luna でも上位 tier の terra とほぼ同水準の精度を達成した．これに対し oss-120b は，luna・terra と共通する誤りに加え，兄弟製品の CPE 混同や同一製品のサブモデル見逃しなど，識別力の限界に起因する固有の誤りが見られた（5.4 節）．これらの多くはタスク 3 で吸収されたが，ER605 × CVE-2024-25139 の 1 件は最終出力でも見逃しとして残った．

なお，3 モデルに共通する誤りとして D-Link DGS-1100 関連の CPE 見逃しがある（5.4 節）．NVD がシリーズ全体を示す表記を用いることに起因する事例であり，モデルの識別力を変えるだけでは解消しない構造的な限界と考えられる．

以上より，製品情報の外部送信が許容できる運用では最も安価な luna で高い精度が得られる．外部送信を避けたい運用でも，oss-120b は Precision 1.000 ／ Recall 0.982

© 2026 Information Processing Society of Japan

という実用的な水準に達しており，検出結果の一部を人手確認する運用と組み合わせれば現実的な選択肢となる．

6.3 制約・今後の課題

本評価と提案手法にはいくつかの制約がある．

評価データセットの限定性．評価データセットは日本国内の特定期間のスキャンで発見され WebUI から製品情報を抽出できた 61 機種に限られる．また，5.2 節で述べた通り，上流の機器情報抽出手法の特性により評価対象はハードウェア機器（IoT 機器）に偏っており，提案手法自体はソフトウェア製品にも適用可能であるにもかかわらず，本評価ではその精度を十分に検証できていない．製品カテゴリやベンダの分布の偏りを含め，本評価で得られた精度がインターネット上の機器・ソフトウェア製品全体に一般化できるとは限らない．評価データセットの拡大やソフトウェア製品を含む追加評価は今後の課題である．

NVD の情報品質への依存．本手法は脆弱性情報の情報源を NVD のみに依存する．CVE・NVD・ベンダアドバイザリ間には影響製品やバージョン範囲の記載の食い違いが報告されており [7]，NVD の記載自体が不正確な場合，本手法はその誤りをそのまま引き継ぐ．

CVE 収集の網羅性．候補収集は製品名を検索語とする NVD 検索に依存するため，CPE 未登録かつ説明文にも型番が明記されない CVE には構造的に到達できない．実際 direct（5.5 節）は，提案手法の候補収集では一度もヒットしない CVE の中に，精査すると対象製品に該当する可能性が高いものを検出していた（例: BUFFALO WSR-1800AX4 系列に対する CVE-2025-46413）．そうした CVE の回収には NVD 以外の情報源の併用が必要である．

7. 結論

本論文では，CPE の表記ゆれと情報欠落に対応するため，キーワード検索と CPE 検索を併用した候補 CVE の収集と，LLM による製品該当性判定，対象 CPE 選択，ルールベースと LLM を組み合わせたバージョン該当性判定の 3 タスクからなる既知脆弱性特定手法を提案した．実際のインターネット広域スキャンで発見した 製品 61 機種を対象に，パイプラインの出力を見ずに人間が独立に作成した Ground Truth との突合により評価した結果，最も安価な商用 API モデルである gpt-5.6-luna を用いた場合でも，最終的なバージョン該当性判定で Precision 0.982 ／ Recall 1.000 を達成した．今後は，本手法を「am I exposed?」[1] に組み込んで実運用における脆弱性検知精度の向上を図るとともに，NVD の CPE 命名慣行に起因する見逃しの低減，機器情報抽出段階での不正確なバージョン表記への対処，および評価データセットの拡大によるバイアスの低減に取り組む．

謝辞 本研究の一部は JSPS 科研費 26K21216，科研費 26K14820 の助成を受けて行われた．

参考文献

[1] 林 嘉乃，九鬼 琉，合屋琴江，竹内謙仁，山口陽平，藤原信代，彦坂雄一，藤井翔太，村上洸介，佐々木貴之，吉岡克成：am I exposed? IoT 機器の発見・リスク評価・管理者通知を自動化する統合システムの提案，信学技報 381，電子情報通信学会 (2026).
[2] 林 嘉乃，合屋琴江，九鬼 琉，藤井翔太，佐々木貴之，吉岡克成：WebUI を対象とした広域スキャンにおける IoT 機器プロファイリングの自動化，コンピュータセキュリティシンポジウム 2025 論文集，pp. 112–119 (2025).
[3] 大塚瑠莉，吉岡清和，インミンパパ，吉岡克成：Basic 認証要求応答に着目したデバイスフィンガープリントの調査 (2024).
[4] NVD: Vulnerability APIs.
[5] Cheikes, B. A., Waltermire, D. and Scarfone, K.: Common platform enumeration: Naming specification version 2.3, *NIST Interagency Report*, Vol. 7695, No. 8 (2011).
[6] Anwar, A., Abusnaina, A., Chen, S., Li, F. and Mohaisen, D.: Cleaning the NVD: Comprehensive Quality Assessment, Improvements, and Analyses (2020).
[7] Jiang, Y., Jeusfeld, M. and Ding, J.: Evaluating the Data Inconsistency of Open-Source Vulnerability Repositories, *Proceedings of the 16th International Conference on Availability, Reliability and Security*, ARES '21, New York, NY, USA, Association for Computing Machinery, (online), DOI: 10.1145/3465481.3470093 (2021).
[8] Jiang, Y., Shang, F., You, F. T. W., Wang, H., Cong, C. R., Meng, Q., Oo, N., Lim, H. W. and Sikdar, B.: VulCPE: Context-Aware Cybersecurity Vulnerability Retrieval and Management (2025).
[9] Ashokkumar C, Mikami, S. and Ideguchi, K.: Semi-Automation of CPE Matching for Vulnerability Management, 2021 年 暗号と情報セキュリティシンポジウム（SCIS2021）予稿集，3F4-3 (2021).
[10] Shodan: Shodan Search Engine.
[11] Huang, S., Griffioen, H., van der Horst, M., Smaragdakis, G., van Eeten, M. and Zhauniarovich, Y.: Trust but Verify: An Assessment of Vulnerability Tagging Services, *34th USENIX Security Symposium (USENIX Security 2025)*, USENIX Association, pp. 823–842 (2025).
[12] Hu, W. and Thing, V. L. L.: CPE-Identifier: Automated CPE identification and CVE summaries annotation with Deep Learning and NLP (2024).
[13] 佐々木満春，山嵜麿与：脆弱性管理のための CPE マッチング手法の提案，コンピュータセキュリティシンポジウム 2021 論文集，pp. 484–491 (2021).
[14] Sawant, D., Hanawal, M. K. and Kabra, A.: Improving Discovery of Known Software Vulnerability For Enhanced Cybersecurity (2024).
[15] Chen, T., Li, L., Zhu, L., Li, Z., Liu, X., Liang, G., Wang, Q. and Xie, T.: VulLibGen: Generating Names of Vulnerability-Affected Packages via a Large Language Model (2024).
[16] NVD: CVEs and the NVD Process.
[17] Cheikes, B. A., Waltermire, D. and Scarfone, K.: Common platform enumeration: Naming specification version 2.3, *NIST Interagency Report*, Vol. 7695, No. 8 (2011).
[18] Davis, J. C., Chen, S., Peng, H., Amusuo, P. C. and Kalu, K. G.: A Guide to Stakeholder Analysis for Cybersecurity Researchers (2025).

© 2026 Information Processing Society of Japan

研究倫理

本研究は，インターネット広域スキャンで発見された製品の製品情報（ベンダ名，製品名，バージョン）を NVD と照合し，LLM を用いて当該製品が影響を受ける既知脆弱性を特定するものである．このような研究は，機器管理者への注意喚起での応用を通じてインターネット全体の安全性向上に資する一方，スキャンに由来する第三者機器の情報の利用，外部 LLM サービスへの製品情報の送信，露出機器と脆弱性の対応情報の悪用，誤判定による不利益，公共の脆弱性データベースへの問い合わせ負荷といった倫理的リスクを伴う．そこで以下では，Stakeholder-Based Ethics Analysis[18] の枠組みに基づき，研究の実施過程に直接関わるステークホルダーと，間接的に影響を受けるステークホルダーの双方を挙げ，それぞれの便益とリスクを検討した上で，リスクの緩和策と公表の妥当性を論じる．

ステークホルダーと便益・リスク

IoT 機器の所有者・管理者および利用者．本研究の成果は，「am I exposed?」[1] の脆弱性特定コンポーネントとして，機器管理者への注意喚起の精度向上に用いられる．見逃し（FN）の低減は対策機会の喪失を防ぎ，過検出（FP）の低減は誤った注意喚起による不要な対応負担を減らすため，脆弱な機器の所有者・管理者，および当該機器を利用するサービスの受益者にとっての便益となる．一方，本研究が評価実験に用いた製品情報は，機器管理者の個別の同意を得ずに実施したインターネット広域スキャンの観測に由来する（**R1**）．また，判定の過程で製品情報が外部の商用 LLM API へ送信されることに伴う，データの取り扱い上の懸念がある（**R2**）．さらに，評価データおよび判定結果は，露出が観測され既知脆弱性への該当が確認された機種・バージョンの一覧としての性質を持つため，漏洩または公開された場合には攻撃対象の選定に利用され得る（**R3**）．加えて，判定の誤りが個別製品に対する評価としてそのまま利用された場合，過検出は不要な対応負担や不安を，見逃しは誤った安心を管理者に与える可能性がある（**R4**）．また，製品情報から既知脆弱性を自動で特定する本手法は，防御目的の注意喚起だけでなく，攻撃対象とする脆弱な製品の選別にも転用され，所有する製品が攻撃の対象となる可能性がある（**R5**）．

NVD の運用者（NIST）．本手法は候補 CVE の収集とバージョン判定のために NVD API へ問い合わせを行うため，大量の製品に適用した場合には API に負荷を与える可能性がある（**R6**）．

IoT 機器のベンダ．自社製品の脆弱な露出状態が減少し，製品起因のインシデントを未然に防げる点で，機器ベンダにも便益がある．一方，論文中で機種名が既知脆弱性への該当と対応付けて記載されることによる，レピュテーション上の不利益が考えられる（**R3**）．ただし，製品と既知脆弱性の対応関係自体は NVD で公開された情報であり，本研究が新たに加える情報は当該機種の露出が実際に観測されたという事実に限られる．また，過検出（**R4**）により本来該当しない脆弱性が対応付けられた場合，この不利益は誤った情報に基づいて生じることになる．

セキュリティ実務者および研究者．本研究は，CPE の表記揺れと情報欠落の下で製品情報と既知脆弱性を対応付ける手法と，その精度がモデル規模によってどう変化するかの知見を提供するものであり，脆弱性管理や注意喚起に関する今後の研究および防御実務に資する．

社会および重要インフラの利用者．脆弱な状態で露出した IoT 機器の減少は，サイバー攻撃の入口やボットネットの構成要素を減らし，重要インフラを含む社会全体の安全性向上に寄与し得る．一方，**R3・R5** のリスクが現実化して重要インフラに設置された機器への攻撃につながった場合，その影響は機器の所有者にとどまらず，インフラの提供を受ける利用者にも波及し得る．

リスクを低減するための緩和策

R1：スキャン由来の製品情報の利用．スキャンおよび製品情報の抽出にあたっては，製品への影響を抑えるため，通信をトップページの取得に限定するとともに，スキャナサーバに研究目的・実施機関・連絡先を明示した Web ページを設置し，スキャン対象からの除外（オプトアウト）の申請を受け付けた．目的の明示とオプトアウトの受付は，事前に個別の同意を得ることが現実的でない広域スキャンにおいて，観測を望まない機器管理者の意思を研究に反映し，その自律性を尊重するための措置である．なお，本評価に用いたスキャンの実施期間中，オプトアウトの申請はなかった．本研究はここから抽出済みの製品情報（ベンダ名，製品名，バージョンの 3 つ組）のみを扱い，IP アドレスなど製品の所在や所有者を特定し得る情報は使用しない．

R2：外部 LLM へのデータ送信リスク．商用 LLM API へ送信した情報は，製品情報の 3 つ組と，NVD から取得した公開情報（CVE 説明文および CPE 一覧）に限られ，本手法の範囲では IP アドレスやスキャンで取得した生データは送信していない．また，API の利用にあたっては，送信したデータが提供元によるモデルの学習に使われない契約条件であることを確認した．さらに，外部へのデータ送信自体を避けたい運用に向けて，ローカル LLM を用いた場合の精度も評価し，外部送信を伴わない構成が実用上の選択肢となることを示した．

R3：露出製品と脆弱性の対応情報の悪用リスク．評価に用いた製品情報および Ground Truth は公開せず，研究目的での利用に限り著者への請求に応じて提供する（付録 A.1）．本文中の機種名の記載は手法の説明に必要な最小限にとどめ，製品の所在や所有者を特定し得る情報は記載し

© 2026 Information Processing Society of Japan

ない．また，本手法が「am I exposed?」に組み込まれた際の判定結果は，個別機器の脆弱性情報へのアクセスを当該機器の管理者および関係者に制限する同システムの方針 [1] のもとで管理される．

R4：誤判定による不利益．本研究では，LLM の判定結果を個別製品に対する確定的な評価として扱わず，Ground Truth との突合による精度の定量化と誤り原因の分析に用いた．評価により，最終判定に至る前段の誤りの多くが後段で緩和されること，および精度がモデル規模に依存して大きく変化することを明らかにしており，これらの知見は実運用時のモデル選定や人手確認の要否判断の根拠となる．

R5：手法の悪用リスク．本論文で公表するのは，手法の設計，プロンプト，および集計された評価結果であり，個別の製品の特定や攻撃の実行に直接利用できる情報は含まない．また，本手法は NVD として公開済みの脆弱性情報と製品情報の突き合わせを自動化するものであり，脆弱性の悪用手順等の攻撃に必要な情報を新たに生成するものではない．

R6：NVD API への負荷．NVD への問い合わせは，API キーを取得した上で，NIST の定めるレートリミットを遵守して実施した．

公表の妥当性

本研究には，緩和策を講じた後も，手法が脆弱な製品の探索の効率化に転用され得るというリスク（**R5**）が残る．しかし，製品情報から NVD を照合すること自体は既存の検索サービスと CPE 検索の組合せによって従来から可能であり，本手法が改善するのは表記揺れや CPE の不備によって対応付けに失敗するケースである．無差別な攻撃を行う攻撃者にとっては露出製品への攻撃試行を直接行う方が低コストであり，事前に既知脆弱性を精査する本手法の転用が攻撃能力に与える増分は限定的と考える．一方，防御側にとっては，従来取りこぼされていた露出製品と既知脆弱性の対応を高い精度で検出し，管理者への注意喚起の信頼性を高めるという具体的な便益がある．以上を踏まえ，本研究の公表がもたらす防御上・学術上の便益は，緩和策を講じた上でなお残るリスクを上回ると判断し，本成果を公表するに至った．

付　　録

A.1　Open Science

本研究が用いたデータと成果物の公開方針を述べる．本手法の再現に必要な情報として，判定に用いたプロンプトの全文および NVD への問い合わせ方法を付録 A.2・A.3 に示しており，照合先の NVD API は一般に公開されているため，本手法は任意の製品情報に対して適用・再現できる．評価に用いた製品情報（ベンダ名・製品名・バージョンの 3 つ組，61 機種）および研究者らが作成した Ground Truth は，評価の再現を可能とするため，研究目的での利用に限り，著者への請求に応じて提供する．

```
# キーワード検索
GET /rest/json/cves/2.0
    ?keywordSearch=VPN Plus Server

# CPE 検索
GET /rest/json/cves/2.0
    ?virtualMatchString=
        cpe:2.3:*:*:vpn_plus_server:*:*:*:*:*:*:*:*
```

図 A·1　候補 CVE 収集で発行するリクエストの例（製品名 VPN Plus Server の場合）

A.2　NVD API への問い合わせ

4.2 節の候補 CVE 収集は，いずれも NVD CVE API 2.0 （`https://services.nvd.nist.gov/rest/json/cves/2.0`）への GET リクエストで行う．2 系統の違いは検索パラメータのみである．発行するリクエストの例を図 A·1 に示す．

キーワード検索では，製品名を `keywordSearch` に指定する．NVD はこの検索語を空白で分割し，全ての語を説明文に含む CVE を返すため，製品名が複数語からなる場合は，その全てを説明文に含む CVE のみが得られる．

CPE 検索では，製品名を小文字化して空白をアンダースコアに置換したものを CPE 2.3 形式の product 属性に埋め込み，他の属性を全てワイルドカードとした文字列を `virtualMatchString` に指定する．このパラメータは指定した属性のみで CVE の CPE 適用条件と照合するため，part とベンダ名の表記に依存せずに検索できる．version をワイルドカードとしているため，この検索ではバージョンによる絞り込みは行われない．

A.3　提案手法で LLM に与えたプロンプト

4 章の各タスクで LLM に与えたシステムプロンプトの全文を示す．製品該当性判定（4.3 節）に用いるものを図 A·2，バージョン判定の対象とする CPE の絞り込み（4.4 節）に用いるものを図 A·3，バージョン該当性判定（4.5 節）に用いるものを図 A·4 に示す．製品情報と候補 CVE は，本文で述べた形式でユーザプロンプトに与える．

A.4　ベースライン手法の詳細

5.5 節で提案手法との比較に使用したベースライン手法において，LLM に与えたシステムプロンプトを図 A·5 に示す．また，ユーザプロンプトの書式を図 A·6 に，出力形式を指定する Structured Outputs スキーマを図 A·7 に示す．

© 2026 Information Processing Society of Japan

```
You are a cybersecurity expert.
This is part of a process for identifying
vulnerabilities in IoT devices.
Strictly determine whether each entry in the
given CVE list is genuinely relevant to the
specified product and vendor.
Base your judgment on both the description and
affected_cpe_products (the products enumerated in
 the CVE's NVD CPE applicability ranges).
Match the target product/vendor against this data
 by meaning, not by exact string. The target
product/vendor was extracted by an upstream
automated step, so its form is not guaranteed (it
 may be a marketing name, an abbreviation, a
series name, or carry extra/garbled tokens),
while affected_cpe_products use CPE notation (
lowercase, underscores for spaces). Treat such
variants as the same product/vendor.
- If the target product appears in
affected_cpe_products, set relevant=true even
when the description contains no model number.
- If affected_cpe_products is empty (no CPE
assigned), judge from the description alone: set
relevant=true only when the description names the
 target product (a vendor-only match is NOT
sufficient). Do not exclude an entry solely
because CPE information is missing.
- Set relevant=false only when none of the above
applies and relevance to the target device
genuinely cannot be confirmed.
Return exactly one result object for every CVE in
 the input, copying each cve_id verbatim. Write
every reason in English.
Return the result as a JSON object:
{"results": [{"cve_id": "CVE-XXXX-XXXXX", "
relevant": true | false, "reason": "brief
justification"}]}
```

図 A·2 製品該当性判定に用いるシステムプロンプト

A.5 評価対象データセットの製品カテゴリ内訳

評価対象とした 61 機種の製品カテゴリ別内訳を表 A·1 に示す．カテゴリは，製品名・型番から推定したものであり，実際の用途と異なる可能性がある．

```
You are a cybersecurity expert.
This is part of a process for identifying
vulnerabilities in IoT devices.
From the given CPE list, select only the entries
for the SAME product as the specified device (
same vendor, same product line), regardless of
version, build identifier, or part type (hardware
/firmware).
Do NOT include a different product, model,
sibling/related product line, or dependency (e.g
., underlying OS, hypervisor, bundled library) —
 even if made by the same vendor or listed under
the same CVE. Version-level filtering happens in
a later step; product identity does not.
Return each selected CPE string exactly as it
appears in the input; do not modify, reformat, or
 invent any CPE string. Only return strings that
are present in the input list. If none apply,
return an empty list.
Return the result as a JSON object:
{"results": ["cpe:2.3:...", ...]}
No preamble or trailing text.
```

図 A·3 対象 CPE 選択に用いるシステムプロンプト

表 A·1 評価対象データセットの製品タイプ内訳（製品名・型番からの推定）

製品タイプ	台数
無線 LAN ルータ／ブロードバンドルータ	22
NAS ／ファイルサーバ	9
物理セキュリティ（入退室管理・電子錠）	5
スイッチ	5
VPN ルータ	3
ネットワークカメラ・監視関連	3
メールサーバ／管理アプライアンス	2
太陽光発電監視ユニット	2
GNSS 受信機（測量機器）	2
産業用制御機器	2
Wi-Fi 中継機／アクセスポイント	2
無線ゲートウェイ	1
UTM ／ファイアウォール	1
仮想化基盤	1
用途不明	1
合計	61

© 2026 Information Processing Society of Japan

```
You are a cybersecurity expert.
This is part of a process for identifying
vulnerabilities in IoT devices.
For each CVE, decide whether the specified device
 version is affected.
Each CVE provides "description" and "matched_cpes
" (CPE entries with optional
versionStartIncluding/Excluding and
versionEndIncluding/Excluding boundaries).
Follow these rules strictly:
- First confirm that the CVE's target product is
the SAME product line as the specified device.
Compare it against the vendor and product, not
just numbers. If the description refers to a
different product line (even from the same vendor
), answer vulnerable=false; do NOT compare
version numbers across different products.
- When the product line matches, prefer the
version boundaries in matched_cpes when they are
present and interpretable; otherwise extract the
affected or fixed version from the description (e
.g. "before X.Y", "prior to X.Y", "versions up to
 X.Y"). Judge whether the specified version falls
 within the affected range.
- Apply version boundaries precisely: "before X"
/ "prior to X" / "fixed in X" mean affected when
version < X (X itself is NOT affected); "X and
earlier" / "up to and including X" / "through X"
mean affected when version <= X. Compare versions
 component-by-component numerically, not as
strings (e.g. 1.2.10 > 1.2.9).
- If neither matched_cpes nor the description
gives a usable version constraint, answer
vulnerable=false.
Return exactly one result object for every CVE in
 the input, copying each cve_id verbatim. Write
every match_reason in English.
Return the result as a JSON object:
{"results": [{"cve_id": "CVE-XXXX-XXXXX", "
vulnerable": true | false, "match_reason": "brief
 reason (e.g. fixed in 1.3.0; 1.2.5 is earlier)",
 "matched_cpe": "the matched_cpes criteria used
for the decision, or null if decided from the
description"}]}
```

図 A·4 バージョン該当性判定に用いるシステムプロンプト

```
You are a cybersecurity expert.
List the known CVEs (vulnerabilities) that affect
 the given IoT device.
You may search the web, but use only the National
 Vulnerability Database
(NVD, nvd.nist.gov) as your vulnerability
database.
Respond with JSON only:
{"cves": [{"cve_id": "CVE-XXXX-XXXXX", "reason":
"brief justification"}]}
```

図 A·5 ベースライン手法に用いるシステムプロンプト

```
{
  "vendor": "ベンダ名",
  "product": "製品名",
  "version": "バージョン"
}
```

図 A·6 ベースライン手法に用いるユーザプロンプトの書式.「ベンダ名」「製品名」「バージョン」の部分には，実際には入力される製品情報が入る

```
{
  "type": "object",
  "properties": {
    "cves": {
      "type": "array",
      "items": {
        "type": "object",
        "properties": {
          "cve_id": {"type": "string"},
          "reason": {"type": "string"}
        },
        "required": ["cve_id", "reason"],
        "additionalProperties": false
      }
    }
  },
  "required": ["cves"],
  "additionalProperties": false
}
```

図 A·7 ベースライン手法で用いた Structured Outputs スキーマ

© 2026 Information Processing Society of Japan